PT PEMBANGUNAN ACEH (PERSERODA)

Laporan Tinjauan Keamanan

Backend Laravel — Sistem Informasi PT PEMA
(api.pema.co.id)

Versi 1.0 • 26 Oktober 2026
Disusun oleh Tim Teknologi Informasi
Klasifikasi: **RAHASIA — Internal**

1. Ringkasan Eksekutif

Tinjauan ini dilakukan menyusul rilis keamanan kritis PHP tanggal 21 Oktober 2026 yang menambal dua celah eksekusi kode jarak jauh (RCE). Pemeriksaan diperluas ke konfigurasi server, dependensi, autentikasi, dan penanganan berkas pada backend Laravel.

Tinjauan menemukan **satu indikator peretasan yang sudah terjadi** (sebuah *webshell* pada direktori unggahan) serta sejumlah celah yang memungkinkan hal itu terjadi dan dapat terjadi lagi. Seluruh temuan yang dapat diperbaiki lewat kode telah diperbaiki; sebagian lagi memerlukan tindakan manual di server oleh administrator.

Perhatian utama — perlu tindakan segera di server:

- **Perbarui PHP** ke 8.3.36 (saat ini produksi memakai PHP 8.3.6, rentan CVE-2026-109618 & CVE-2026-109619).
- **Investigasi dugaan peretasan**: sebuah webshell ditemukan di server. Lihat Temuan T-01.
- **Matikan mode debug** di `.env` produksi (`APP_DEBUG=false`, `APP_ENV=production`).
- **Ganti seluruh kredensial** yang pernah tampil pada log/debug dan reset password akun.

Kategori	Jumlah
Kritis (Critical)	3
Tinggi (High)	4
Sedang (Medium)	4
Rendah / Informasi	2

2. Konteks: Rilis Keamanan PHP Oktober 2026

Pada 21 Oktober 2026 PHP merilis tambalan untuk dua kerentanan kritis, keduanya bernilai CVSS 9.2:

CVE	Uraian
CVE-2026-109618	RCE melalui kerusakan memori saat kondisi kehabisan memori (OOM); data permintaan dapat dianggap valid secara keliru.
CVE-2026-109619	RCE melalui *stale global state*; data milik satu permintaan dapat dipakai permintaan berikutnya pada worker yang sama.
CVE-2026-115560	Terkait `session.upload_progress`; advisori lanjutan menyusul.

PHP menyatakan **semua instalasi yang melayani permintaan web terdampak** (PHP-FPM, Apache mod_php, php-cgi, FrankenPHP, LiteSpeed), dan **satu-satunya perbaikan tuntas adalah memperbarui PHP**. Versi yang sudah diperbaiki per cabang:

Cabang	Versi aman	Status produksi PT PEMA
8.2	8.2.35	(berakhir dukungan 31 Des 2026)
8.3	**8.3.36**	**Saat ini 8.3.6 — RENTAN, wajib diperbarui**
8.4	8.4.27	
8.5	8.5.12	

Sumber: php.net (advisory 21 Okt 2026), Simon Willison's Weblog, Sophos. Versi PHP produksi diperoleh dari halaman `phpinfo` yang sebelumnya terbuka (lihat T-06).

3. Ringkasan Temuan

Kode	Temuan	Tingkat	Status
T-01	Webshell pada direktori unggahan (indikasi peretasan)	**KRITIS**	**Dihapus** + perlu investigasi server
T-02	Unggah berkas tanpa validasi tipe (jalur RCE)	**KRITIS**	**Diperbaiki**
T-03	PHP produksi rentan (CVE-2026-109618/619)	**KRITIS**	**Tindakan server**
T-04	Login SSO dapat dilewati (login tanpa kata sandi)	**TINGGI**	**Diperbaiki**
T-05	Mode debug aktif di produksi (bocor jejak & konfigurasi)	**TINGGI**	**Tindakan server**
T-06	Endpoint `phpinfo` & `error_log` terbuka publik	**TINGGI**	**Diperbaiki**
T-07	Password bawaan seragam untuk akun pegawai	**TINGGI**	**Kode diperbaiki** + perlu reset
T-08	Pendaftaran akun publik memberi peran Employee	**SEDANG**	**Diperbaiki**
T-09	Endpoint data pegawai tanpa autentikasi	**SEDANG**	**Diperbaiki**
T-10	Tidak ada pembatasan percobaan login (brute force)	**SEDANG**	**Diperbaiki**
T-11	Dependensi (Composer) memiliki kerentanan	**SEDANG**	**Sebagian besar diperbaiki**
T-12	Perbandingan rahasia klien tidak aman & CORS terbuka	**RENDAH**	**Sebagian**

4. Detail Temuan & Perbaikan

T-01 — Webshell pada direktori unggahan KRITIS

Temuan: ditemukan berkas `public/inven/akta/jF7Cf.php` (773 KB) berisi kode PHP ter-*obfuscate* (penanda "Encryptor by yenpro.net"). Ini adalah *webshell* — program yang memberi penyerang kendali atas server. Keberadaannya berarti server **kemungkinan besar pernah diretas**.

Dampak: eksekusi perintah jarak jauh, pencurian data, dan akses berkelanjutan ke server.

Perbaikan: berkas telah dihapus dari repositori. Namun penghapusan berkas saja tidak cukup — diperlukan investigasi di server (lihat Bagian 5).

> **Wajib di server:** hapus berkas yang sama di server produksi bila masih ada, periksa seluruh direktori `public/` untuk berkas `.php` lain yang tidak dikenal, telusuri log akses web di sekitar tanggal berkas dibuat, dan asumsikan kredensial telah bocor.

T-02 — Unggah berkas tanpa validasi tipe KRITIS

Temuan: beberapa endpoint unggah menyimpan berkas ke dalam `public/` memakai nama/ekstensi asli dari pengguna tanpa penyaringan, antara lain pada modul Task, Project, Kontrak, dan Layar. Inilah jalur yang paling mungkin dipakai untuk menaruh webshell T-01.

Perbaikan:

- Dibuat helper `App\Support\SafeUpload` yang menolak ekstensi berbahaya (`.php`, `.phtml`, `.svg`, `.htaccess`, dsb.), termasuk ekstensi ganda seperti `x.php.jpg`, dan membersihkan path.
- Helper diterapkan pada seluruh titik unggah tersebut.
- Berkas `public/.htaccess` diperketat agar **tidak ada berkas PHP di `public/` yang dieksekusi** kecuali `index.php`. Ini lapisan pertahanan kedua: andai sebuah skrip berhasil diunggah, ia tetap tidak akan berjalan.

T-03 — PHP produksi rentan KRITIS

Temuan: produksi menjalankan PHP 8.3.6, rentan terhadap CVE-2026-109618 dan CVE-2026-109619 (lihat Bagian 2).

Perbaikan: perbarui PHP ke 8.3.36 di server (tindakan administrator, lihat Bagian 5). Tidak dapat diperbaiki dari kode aplikasi.

T-04 — Login SSO dapat dilewati TINGGI

Temuan: endpoint `POST /api/auth/login-sso` menerima hanya alamat email, lalu menerbitkan sesi untuk akun mana pun yang emailnya cocok — **tanpa kata sandi atau verifikasi apa pun**. Siapa saja yang tahu email seorang pegawai dapat masuk sebagai pegawai tersebut.

Perbaikan: endpoint kini mewajibkan token JWT yang **ditandatangani** oleh penerbit SSO (algoritma HS256, rahasia `SSO_SHARED_SECRET`) dan masih berlaku. Tanpa rahasia yang dikonfigurasi, login SSO dinonaktifkan sepenuhnya (mengembalikan 403). Diuji: email polos ditolak (403), token palsu/kedaluwarsa/salah-rahasia ditolak (401).

T-05 — Mode debug aktif di produksi TINGGI

Temuan: `APP_DEBUG=true` dan `APP_ENV=local`. Terkonfirmasi: permintaan yang menghasilkan error menampilkan halaman Laravel Ignition berisi jejak kode, potongan konfigurasi, dan versi komponen.

Perbaikan: ubah `.env` produksi menjadi `APP_DEBUG=false` dan `APP_ENV=production` (tindakan administrator). File `.env` tidak berada di repositori sehingga tidak dapat diubah dari sini.

T-06 — Endpoint phpinfo & error_log terbuka TINGGI

Temuan: `GET /vapi/phpinfo` menampilkan konfigurasi PHP lengkap kepada publik, dan `/error_log` (124 KB) dapat diunduh siapa saja, membocorkan path server dan jejak error.

Perbaikan: route `phpinfo` dihapus. Aturan `public/.htaccess` baru memblokir akses ke `error_log`, berkas `.log`, `.sql`, `.env`, dan `.user.ini`. Disarankan juga menghapus berkas `error_log` di server.

T-07 — Password bawaan seragam TINGGI

Temuan: akun yang dibuat dari data pegawai diberi kata sandi yang sama dan tertulis di kode (`asdasdasd`). Pemeriksaan basis data menunjukkan **116 dari 170 akun** masih memakai kata sandi tersebut — siapa pun yang tahu polanya dapat masuk ke akun-akun itu.

Perbaikan: kode pembuatan akun kini memakai kata sandi acak; pengguna mengaktifkan akun lewat menu "Lupa Password". Disediakan perintah `php artisan security:reset-default-passwords --apply` untuk mengganti kata sandi akun lama yang masih memakai nilai bawaan.

T-08 — Pendaftaran akun publik SEDANG

Temuan: `POST /api/auth/register` terbuka untuk umum dan otomatis memberi peran *Employee*, sehingga orang luar dapat membuat akun karyawan.

Perbaikan: route pendaftaran internal dihapus. Akun internal hanya dibuat dari data HR. (Pendaftaran vendor pada `/api/auth2/register` tetap ada sesuai fungsinya, kini dengan pembatasan laju.)

T-09 — Endpoint data pegawai tanpa autentikasi SEDANG

Temuan: beberapa route pegawai tidak memiliki middleware autentikasi, termasuk menampilkan detail (`GET /api/employe/{id}`), menghapus pegawai (`DELETE /api/employe/{id}`), dan data divisi.

Perbaikan: route tampil/divisi kini memerlukan autentikasi (`role:Employee`), dan penghapusan memerlukan kredensial klien (`client`).

T-10 — Tidak ada pembatasan percobaan login SEDANG

Temuan: endpoint login, login-SSO, dan lupa-password tidak dibatasi lajunya, memungkinkan tebakan kata sandi massal.

Perbaikan: ditambahkan pembatas `throttle:10,1` (maksimum 10 percobaan per menit per IP) pada endpoint-endpoint tersebut.

T-11 — Dependensi dengan kerentanan SEDANG

Temuan: `composer audit` awal melaporkan 56 advisori pada 16 paket, antara lain dompdf (baca berkas lokal via SVG), guzzle, league/commonmark (denial of service), symfony/mime (injeksi header email), dan symfony/http-foundation.

Perbaikan: seluruh paket diperbarui ke versi aman dalam batas kompatibilitas. Audit ulang menyisakan **6 advisori**: lima di `laravel/framework` (perbaikan memerlukan kenaikan versi mayor

ke Laravel 12, direncanakan terpisah) dan satu rendah di `firebase/php-jwt`. Risiko sisa tergolong rendah untuk pola pemakaian saat ini.

T-12 — Perbandingan rahasia & CORS RENDAH

Temuan: middleware klien membandingkan rahasia dengan operator `==` (rentan *timing* dan *type juggling*); CORS mengizinkan semua origin (`allowed_origins: *`).

Perbaikan: perbandingan rahasia diganti dengan `hash_equals()`. CORS dibiarkan terbuka untuk saat ini (API dipakai beberapa frontend); disarankan dibatasi ke domain PT PEMA saja pada tahap berikutnya.

5. Tindakan Manual yang Masih Diperlukan (di Server)

Perbaikan kode sudah siap di repositori, tetapi butuh *deploy*. Hal-hal berikut **hanya bisa dilakukan administrator** di server dan tidak tercakup oleh perubahan kode:

No	Tindakan	Prioritas
1	Perbarui PHP ke **8.3.36** (atau cabang lebih baru yang aman), lalu restart PHP-FPM/web server.	**Segera**
2	**Investigasi peretasan**: cari berkas `.php` asing di `public/`, periksa log akses, tabel user, cron/scheduled task, dan kunci API.	**Segera**
3	Set `APP_DEBUG=false` dan `APP_ENV=production` di `.env`.	**Segera**
4	Rotasi kredensial: `APP_KEY`, `JWT_SECRET`, kata sandi basis data, kredensial email, dan kunci pihak ketiga (asumsikan telah bocor).	**Segera**
5	Deploy kode terbaru, lalu jalankan `composer install --no-dev`, `php artisan config:cache`, `route:cache`.	Tinggi
6	Set `SSO_SHARED_SECRET` di `.env` bila fitur login SSO dipakai (jika tidak, biarkan kosong agar nonaktif).	Tinggi
7	Jalankan `php artisan security:reset-default-passwords --apply` lalu minta pengguna memakai "Lupa Password".	Tinggi
8	Hapus berkas `error_log` di `public/` dan root bila ada.	Sedang
9	Pastikan direktori unggahan (`inven`, `taskfiles`, `project`, dll.) tidak mengizinkan eksekusi PHP di level server (bukan hanya `.htaccess`).	Sedang

6. Berkas yang Diubah

Seluruh perubahan ada di repositori backend; belum ada yang di-*commit* (menunggu persetujuan).

Berkas	Perubahan
`public/inven/akta/jF7Cf.php`	Dihapus (webshell)

`public/.htaccess`	Blokir eksekusi PHP di unggahan & akses berkas sensitif
`app/Support/SafeUpload.php`	Baru — validasi nama/ekstensi berkas unggahan
`app/Console/Commands/ResetDefaultPasswords.php`	Baru — perintah reset password bawaan
`app/Http/Controllers/AuthController.php`	SSO wajib token tertandatangani; hapus register; validasi email
`app/Http/Controllers/Auth2Controller.php`	Validasi email (`email:filter`)
`routes/api.php`	Hapus register internal; throttle login; lindungi route pegawai
`routes/vapi.php`	Hapus route `phpinfo`
`app/Http/Middleware/ValidateClient.php`	Perbandingan rahasia dengan `hash_equals`
`Employe/ClientController (store)`	Hapus password bawaan; pakai acak
`Task/Project/Kontrak/Layar Controller`	Terapkan `SafeUpload` pada unggahan
`config/services.php`	Tambah konfigurasi rahasia SSO
`composer.json / composer.lock`	Perbarui dependensi rentan

> **Catatan metodologi.** Pemeriksaan mencakup: `composer audit`, pemetaan route & middleware, penelusuran pola rawan (SQL mentah, path traversal, unggahan), pemeriksaan autentikasi, dan uji langsung terbatas ke produksi (hanya pengamatan, tanpa perubahan data). Perbaikan kode telah diuji secara lokal (lint, uji fungsi endpoint, uji perilaku login SSO). Tinjauan ini bukan uji penetrasi menyeluruh; disarankan audit lanjutan setelah tindakan server selesai.